

LEDGR Security Procedures

- Procedure owner: Branden Nevius
- Effective date: 2026-02-15
- Last reviewed: 2026-02-15

This document operationalizes `/Users/brandennevius/Desktop/Financial Coaching/docs/security/information-security-policy.md`.

1) Access Review Procedure (Quarterly)

Steps:

1. Enumerate production system users (hosting, database, source control, auth provider, Plaid dashboard).
2. Confirm each account has active business need.
3. Remove unnecessary access.
4. Confirm privileged accounts have MFA enabled where available.
5. Record completion in an access review log.

Evidence to retain:

- Date of review
- Reviewer name
- Systems reviewed
- Access removals/changes made

2) Vulnerability and Patch Procedure (Monthly)

Steps:

1. Review dependency vulnerability alerts (`npm audit` and repository alerts).
2. Patch high severity issues immediately; medium within 30 days.
3. Rebuild and smoke test critical API paths after updates.
4. Document unresolved risks with mitigation date.

Evidence to retain:

- Scan date
- Findings summary
- Patch PR/commit references

3) Change Security Review Procedure (Per Release)

Apply before deploying features that touch auth, Plaid data, or user data models.

Checklist:

- Authorization checks present on all new API routes
- Input validation and error handling implemented
- No secrets in code or client bundles
- Data minimization reviewed for new fields/integrations
- Rollback strategy documented

Evidence to retain:

- Release note with security checklist completion

4) Incident Response Procedure (As Needed)

Steps:

1. Detect and triage incident severity.
2. Contain impact (disable endpoint, revoke tokens, rotate keys).
3. Preserve evidence (logs, timestamps, affected resources).
4. Recover service safely.
5. Complete post-incident review with prevention actions.

Severity targets:

- High: begin response immediately
- Medium: begin response within 24 hours
- Low: begin response within 3 business days

Evidence to retain:

- Incident timeline
- Root cause
- Corrective actions and owners

5) Vendor Security Review Procedure (Annually or Before New Vendor)

Steps:

1. Review vendor security documentation and contractual terms.
2. Confirm least-data-sharing design.
3. Verify integration secrets management approach.
4. Record approved vendor purpose and data categories.

Evidence to retain:

- Vendor name
- Review date
- Data shared
- Decision and conditions

6) Data Deletion Procedure (On Request / Account Closure)

Steps:

1. Validate request source and account ownership.
2. Execute account-level deletion workflow.
3. Confirm deletion completion.
4. Log request and completion date.

Evidence to retain:

- Request date
- Completion date
- Data categories deleted

7) Procedure Review and Maintenance

- Review this document at least annually.
- Update procedures after major architecture or vendor changes.
- Keep evidence logs for at least 12 months.